Vulnerability Assessment Report

WEBSITE: OWASP JUICE SHOP

IVA MTSHENGU

This report presents a basic vulnerability assessment conducted on the OWASP Juice Shop web application. The objective was to identify common security weaknesses using passive analysis techniques.
The assessment was performed within a read-only scope using tools such as Browser Developer Tools and OWASP ZAP.

Scope:

- Public pages only
- No exploitation
- Passive analysis

Tools Used:

- Browser DevTools
- OWASP ZAP

Finding 1: Missing Security Headers

Status:
Completed

RISK: Medium

EXPLANATION: The website does not implement important security headers like **Content-Security-Policy** and **Strict-Transport-Security,** which help protect against attacks like data interception

FIX: Configure the server to include those security headers

Headers Preview Response Initiator Timing Cookies

Accept-Ranges	bytes
Access-Control-Allow-Origin	*
Cache-Control	public, max-age=0
Date	Sun, 12 Apr 2026 23:22:40 GMT
Etag	W/"124fa-19d83f183bd"
Feature-Policy	payment 'self'
Last-Modified	Sun, 12 Apr 2026 23:05:36 GMT
Nel	{"report_to":"heroku-nel","response_headers":["Via"],"max_age":3600,"success_fraction":0.01,"failure_fraction":0.1}
Report-To	{"group":"heroku-nel","endpoints":[{"url":"https://nel.heroku.com/reports?s=BpGvDAK3lQKIA9TsZ8WX%2Fp1ZjucPLg1UuEt3HHh9Q30%3D\u0026sid=812dcc77-0bd0-43b1-a5f1-b25750382959\u0026ts=1776036160"}],"max_age":3600}
Reporting-Endpoints	heroku-nel="https://nel.heroku.com/reports?s=BpGvDAK3lQKIA9TsZ8WX%2Fp1ZjucPLg1UuEt3HHh9Q30%3D&sid=0bd0-43b1-a5f1-b25750382959&ts=1776036160"
Server	Heroku
Via	1.1 heroku-router
X-Content-Type-Options	nosniff
X-Frame-Options	SAMEORIGIN
X-Recruiting	/#/jobs

Finding 2: Insecure Cookies

Status: Completed

RISK: Medium

EXPLANATION: Cookies are not protected with Secure and HttpOnly flags, making them vulnerable to theft via network attacks

FIX: Set cookies with Secure and HttpOnly attributes

Elements Console Sources Network Performance Memory Application Security Lighthouse Recorder 33

Application
- Manifest
- Service ...
- Storage

Storage
- Local st...
- Session ...
- Extensi...
- Indexed...
- Cookies
  - https:...
- Private ...
- Interest ...
- Shared ...
- Cache s...

Filter

Only show cookies with an issue

Name	Value	Domain	Path	Expires...	Size	HttpO...	Secure	SameS...	Partiti...	Cross ...	Prior
continueCode	rdj5tXc3c4IEiJSwt66hbaT2zFDOiE3tq2TPwipPcv...	juice-s...	/	2027-0...	72						Med
cookieconsent_status	dismiss	juice-s...	/	2027-0...	27						Med
language	en	juice-s...	/	2027-0...	10						Med
welcomebanner_status	dismiss	juice-s...	/	2027-0...	27						Med

Finding 3: Information Disclosure (Timestamp)

Status: Complete

RISK: Low

EXPLANATION: A timestamp was disclosed by the application. It reveals internal system information. While not critical on its own, this information could help attackers understand system behaviour and potentially assist in attacks

FIX: Manually confirm the timestamp data is not sensitive, and that the data cannot be aggregated to disclose

Header: Text | Body: Text

- Contexts
  - Default Context
- Sites

```
HTTP/1.1 200 OK
Access-Control-Allow-Origin: *
Content-Length: 28
Content-Type: text/plain; charset=utf-8
Date: Sun, 12 Apr 2026 23:37:07 GMT
Etag: W/"1c-8HgF6mNyhsSFK0pascC9uB0wjX0"
Feature-Policy: payment 'self'
Nel: {"report_to":"heroku-nel","response_headers":["Via"],"max_age":3600,"success_fraction":0.01,"failure_fraction":0.1}
Report-To: {"group":"heroku-nel","endpoints":[{"url":"https://nel.heroku.com/reports?s=5IH0XFlAyB96hRSBlYJLndBjgKEwMihXNuHokFbX6ns%3D\u0026sid=812dcc77-0bd0-43b1-a5f1-b25750382959\u0026ts=1776037027"}],"max_age":3600}
Reporting-Endpoints: heroku-nel="
```

```
User-agent: *
Disallow: /ftp
```

History | Search | Alerts | Output | Spider | AJAX Spider | Active Scan

- Alerts (8)
  - Content Security Policy (CSP) Header Not Set (Systemic)
  - Cross-Domain Misconfiguration (Systemic)
  - HTTPS Content Available via HTTP (Systemic)
  - Strict-Transport-Security Header Not Set (Systemic)
  - Timestamp Disclosure - Unix (Systemic)
  - Modern Web Application (Systemic)
  - Re-examine Cache-control Directives (Systemic)
  - User Agent Fuzzer (Systemic)

Evidence: 1776037027
CWE ID: 497
WASC ID: 13
Source: Passive (10096 - Timestamp Disclosure)
Input Vector:

Description:

A timestamp was disclosed by the application/web server. - Unix

Other Info:

1776037027, which evaluates to: 2026-04-13 01:37:07.

Solution:

Manually confirm that the timestamp data is not sensitive, and that the data cannot be aggregated to disclose exploitable patterns.

CONCLUSION:

The assessment identified many security weaknesses, including missing security headers, insecure cookie configuration, and timestamp disclosure.
While no critical vulnerabilities were found, addressing these issues would improve the overall security posture of the application.